

ARG Leads Tracker

Pending Production Security and Go-Live Actions

Management status report and next-day implementation runbook
Prepared for controlled production rollout

CURRENT STATUS

Engineering preparation complete; production activation pending

The security package has passed local syntax checks, automated tests, the production build command, and Git whitespace validation. The changes are still uncommitted locally and are not yet active on the live CRM.

Executive decision requested

Approve a controlled deployment window and nominate the credential owner, QA sign-off owner, and rollback approver. Production deployment must occur only after the Supabase migrations and server-only Vercel secrets are in place.

Decision	Required management response
Deployment window	Approve a low-traffic window with at least 60 minutes for verification.
Credential owner	Assign access to Supabase and Vercel without sharing secret values in email or this report.
QA participants	Provide one admin and two active salesmen in different territories for access-boundary testing.
Rollback authority	Name the person authorized to restore the previous Vercel deployment if a blocking fault occurs.

Key warning: deploying the API before the durable rate-limit migration or required secrets are available will intentionally cause protected production requests to fail closed with HTTP 503.

1. Engineering Controls Prepared

The following controls are implemented in the local working tree. They preserve CRM business logic while strengthening authentication boundaries, private media access, scheduled jobs, browser behavior, and abuse resistance.

Control	Prepared behavior	Production dependency
User-scoped authorization and RLS	Normal Supabase traffic uses the signed-in user's JWT. Leadership and salesman access rules are documented and enforced through canonical RLS policies.	Apply migration 20260730150000 and execute cross-role tests.
Private attachments and voice notes	Uploads and signing use the caller identity. Local media grants expire after five minutes. Unauthorized downloads are denied and logged.	Confirm Storage policies and test cross-user denial.
Cron authentication and idempotency	Scheduled market-intelligence jobs require a bearer credential, reject malformed requests, and avoid duplicate work within the same run window.	Configure a 32-byte CRON_SECRET in Vercel.
Browser security headers	CSP, frame denial, MIME sniffing prevention, referrer controls, and permissions restrictions are applied at application and Vercel routing layers.	Verify headers on the final production URL.
Service-role allowlist	Privileged Supabase access is limited to explicit operations such as admin account creation, cron processing, leadership notifications, and manager lookup.	Confirm the service-role key remains server-only.
Durable rate limiting	Login and expensive API operations share hashed, atomic counters across serverless instances. Threshold responses include 429 and Retry-After.	Apply migration 20260730170000 and set RATE_LIMIT_HASH_SECRET .

Local validation evidence - 30 July 2026

Check	Result	Evidence
npm run check	PASS	JavaScript syntax checks passed for application, services, functions, and tests.
npm test	PASS	All configured suites passed, including authorization, cron, voice-note media, security headers, and durable rate limiting.
npm run build	PASS	Production build command completed successfully.
git diff --check	PASS	No whitespace errors. Two line-ending conversion warnings were non-blocking.

Not yet validated: production Supabase schema, production environment variables, direct PostgREST isolation, Storage isolation, production 429 behavior, cron execution, or post-deployment monitoring.

2. Pending Production Blockers

Priority	Pending item	Why it matters	Owner
P0	Apply RLS migration 20260730150000_enforce_user_scoped_rls.sql .	Without the deployed policies, the new server authorization contract is not proven against the live database.	Supabase owner
P0	Apply rate-limit migration 20260730170000_add_durable_rate_limits.sql .	The production API fails closed when the durable bucket table or RPC is unavailable.	Supabase owner
P0	Configure server-only Vercel secrets.	Cron, session signing, service access, and HMAC subject hashing require valid private values.	Vercel owner
P0	Commit and push the prepared source changes.	The current production deployment cannot receive controls that remain only in the local working tree.	Developer
P0	Deploy a new production version after database and secrets are ready.	Environment-variable changes only apply to new deployments.	Developer
P1	Execute live role, Storage, cron, and rate-limit tests.	Local tests cannot prove production project configuration, RLS behavior, or cross-user isolation.	Developer + QA
P1	Monitor production security events for 24-48 hours.	Threshold tuning and unexpected denials are visible only under real traffic.	Operations

Required Vercel configuration

Variable	Requirement	Handling
APP_SESSION_SECRET	Strong random server-only session secret.	Confirm present; never expose to browser code.
SUPABASE_SERVICE_ROLE_KEY	Current production service-role credential.	Server-only; never prefix with NEXT_PUBLIC.
CRON_SECRET	At least 32 random bytes.	Must match the bearer credential used by Vercel Cron.
RATE_LIMIT_HASH_SECRET	At least 32 random bytes and identical across production instances.	Used only to HMAC-hash rate-limit subjects.
RATE_LIMIT_TENANT_ID	arg-leads-tracker	Keep consistent across production instances.
NEXT_PUBLIC_SUPABASE_URL	Production Supabase URL.	Public configuration; verify it points to the intended project.
NEXT_PUBLIC_SUPABASE_ANON_KEY	Production anonymous key.	Public client key; RLS must remain the enforcement boundary.

No secret values are included in this report. Secrets should be generated and entered directly into Vercel by the authorized credential owner.

3. Controlled Rollout Runbook

Phase A - Pre-deployment preparation

- ☐ Approve a low-traffic deployment window and identify the rollback approver.
- ☐ Create or confirm a current production database backup or restore point.
- ☐ Prepare one admin and two active salesman test accounts in different territories.
- ☐ Record the current Vercel production deployment ID for immediate rollback.
- ☐ Confirm the production URL and Supabase project reference before making changes.

Phase B - Database activation

- ☐ Apply `20260730150000_enforce_user_scoped_rls.sql` first.
- ☐ Apply `20260730170000_add_durable_rate_limits.sql` second.
- ☐ Confirm the private rate-limit table and consume/reset RPC functions exist.
- ☐ Confirm only service_role can execute the rate-limit RPC functions.
- ☐ Run direct PostgREST checks as each salesman and confirm the other salesman's rows are absent.
- ☐ Attempt cross-user update, delete, file signing, and file download; require 403/404 and no data change.

Phase C - Vercel configuration

- ☐ Generate separate strong values for APP_SESSION_SECRET, CRON_SECRET, and RATE_LIMIT_HASH_SECRET.
- ☐ Add or verify all required variables under Vercel Project Settings - Environment Variables.
- ☐ Apply values to Production and any Preview environment used for acceptance testing.
- ☐ Do not place private values in .env.example, Git, screenshots, tickets, or this report.
- ☐ Save variables, then create a new deployment because previous deployments do not inherit changes.

Phase D - Source publication and deployment

- ☐ Review the working-tree diff and confirm no unrelated or credential files are staged.
- ☐ Commit the security package with both migration files and supporting documentation.
- ☐ Push the approved branch to GitHub.
- ☐ Deploy the exact pushed commit to Vercel production.
- ☐ Keep the previous production deployment available until final acceptance is complete.

Phase E - Immediate live verification

Test	Expected result
Homepage and health endpoint	Page returns 200; /api/health reports healthy without exposing secrets.
Anonymous protected API	/api/settings and other protected routes return 401.
Admin login	Admin sees organization-level records and permitted actions.
Salesman isolation	Each salesman sees only permitted leads, reports, activities, and private files.
Rate-limit threshold	A disposable invalid login account eventually returns 429 with Retry-After.
Cron authentication	Unsigned call is rejected; valid scheduled call runs once per window.
Voice note and attachments	Authorized user can access; other salesman is rejected.
Security headers	CSP, DENY frame policy, nosniff, referrer, and permissions headers are present.

4. Rollback and Incident Criteria

Trigger	Immediate action	Follow-up
Protected routes return widespread 503	Restore the previous Vercel deployment.	Verify migration/RPC existence, service-role key, and rate-limit secret before retry.
Salesman can see another salesman's restricted data	Stop rollout and restrict affected access immediately.	Review RLS policies and server caller-token propagation. Treat as a security incident.
Private media is accessible cross-user	Disable affected media route or roll back.	Audit Storage policies and signed URL authorization.
Legitimate users receive excessive 429 responses	Check telemetry and policy scope before changing thresholds.	Adjust only documented environment overrides and redeploy.
Cron repeats or runs without authorization	Disable the cron schedule or roll back.	Rotate CRON_SECRET and inspect idempotency logs.

Monitoring during the first 24-48 hours

- [] Watch Vercel logs for rate_limit_exceeded, rate_limit_near_threshold, scheduled_job_rejected, and voice_note_media_access events.
- [] Track unexpected 401, 403, 429, and 503 response spikes.
- [] Confirm scheduled market-intelligence processing completes once and records a safe structured log.
- [] Review user reports for blocked workflows, especially Activity attachments, voice notes, AI actions, exports, searches, and weekly reports.
- [] Do not lower protections solely to hide an error; identify whether the cause is configuration, authorization, or a true threshold issue.

Risk position

CURRENT LIVE RISK	DEPLOYMENT RISK
Prepared controls are not active The live CRM remains on the last deployed version until publication and deployment.	Manageable with sequencing Database and secrets must be ready before the API is deployed.

5. Tomorrow's Continuation Checklist

Use this page as the working handoff. Do not mark the production rollout complete until every P0 item and every acceptance test below has an accountable owner and recorded result.

Seq.	Action	Owner	Status
1	Confirm deployment window, backup, test accounts, and rollback approver.	Management / Operations	Pending
2	Apply RLS migration 20260730150000 to production Supabase.	Supabase owner	Pending
3	Apply rate-limit migration 20260730170000 to production Supabase.	Supabase owner	Pending
4	Configure and verify Vercel server-only secrets.	Vercel owner	Pending
5	Review, commit, and push the prepared source changes.	Developer	Pending
6	Deploy the pushed commit to Vercel production.	Developer	Pending
7	Run admin, salesman, RLS, Storage, cron, header, and rate-limit checks.	Developer + QA	Pending
8	Obtain business-owner sign-off on critical workflows.	CRM owner	Pending
9	Begin 24-48 hour monitoring and record any threshold tuning decision.	Operations	Pending

Production acceptance criteria

- ☐ All required migrations are present in the intended production Supabase project.
- ☐ All private Vercel variables are configured and absent from browser bundles and source control.
- ☐ Admin permissions work and salesman records remain isolated by ownership, assignment, and territory rules.
- ☐ Private attachments and voice notes cannot be signed or downloaded by unauthorized users.
- ☐ Protected operations return 429 with Retry-After after their configured threshold.
- ☐ No sustained unexplained 401, 403, 429, or 503 errors occur during acceptance testing.
- ☐ The current dashboard, pipeline, activity, tasks, AI assistant, exports, and reports remain functional.
- ☐ Management and the CRM owner approve the rollout or explicitly authorize any accepted residual risk.

RECOMMENDED NEXT INSTRUCTION

Resume only after database and Vercel prerequisites are confirmed

Send the implementation team: "Production migrations applied and Vercel secrets configured." The team can then review, commit, push, deploy, and perform the live verification sequence.

Reference files

- docs/API_AUTHORIZATION_MATRIX.md
- docs/DURABLE_RATE_LIMITING.md
- supabase/migrations/20260730150000_enforce_user_scoped_rls.sql
- supabase/migrations/20260730170000_add_durable_rate_limits.sql
- .env.example

External operational references: Supabase database migrations - <https://supabase.com/docs/guides/deployment/database-migrations>
 Vercel environment variables - <https://vercel.com/docs/projects/environment-variables>